

Rete Compagnia THETA

Report tecnico completo: architettura di rete, configurazioni hardware, politiche di sicurezza e audit delle vulnerabilità condotto dal team di Cybersecurity & Ethical Hacking.

CYBERSECURITY & ETHICAL HACKING

GRUPPO DI LAVORO INTEGRATO



Team members

A professional team focused on collaboration, cybersecurity, and shared delivery.

**Lorenzo
Buffolino**

Alex Tarantino

**Imane
Chaabane**

**Leonardo
Onori**

**Lorenzo
Rizzuti**



Panoramica della Rete

La rete THETA è composta da **120 postazioni** distribuite su 6 piani (20 PC per piano), con un'architettura a tre zone di sicurezza.

WAN (Internet)

Collegamento al cloud e ISP 4
Subnet: **200.0.0.0/30**

INTERNAL

Rete interna aziendale 4 VLAN 10370
4 Subnet: **192.168.10.0/24 –**
192.168.70.0/24

DMZ

Servizi esposti 4 VLAN 100 4 Subnet:
192.168.100.0/24

Mappa VLAN e Reparti

Piano	Reparto	VLAN	Subnet	Gateway
1	Segreteria	10	192.168.10.0/24	192.168.10.1
2	Sales Market	20	192.168.20.0/24	192.168.20.1
3	Procurement	30	192.168.30.0/24	192.168.30.1
4	Ingegneri	40	192.168.40.0/24	192.168.40.1
5	IT	50	192.168.50.0/24	192.168.50.1
6	Direttori	60	192.168.60.0/24	192.168.60.1
—	Server Inter	70	192.168.70.0/24	192.168.70.1
—	DMZ	100	192.168.100.0/24	192.168.100.1

Hardware e Dispositivi



Firewall Perimetrale

Cisco ASA 5505 —
Protezione da
Internet

Firewall DMZ

Cisco ASA 5505 —
Isolamento DMZ

Router Centrale

Cisco 2911 —
Gateway e routing
inter-VLAN

Switch Core

Cisco Catalyst
2960-X 48 porte —
Backbone

Switch di Piano

6× Cisco Catalyst
2960 — Accesso per
6 piani

Router IDS

3× Cisco 2811 —
Monitoraggio NAS,
Web Server e
traffico aggiuntivo

Configurazioni Chiave

1

Router Centrale (2911)

Router-on-a-stick: sub-interfacce dot1Q per VLAN 10–70 e 100. Route di default verso ASA-EDGE (10.0.1.1).

2

Firewall Perimetrale

ASA-EDGE: PAT dinamico per uscita Internet. ACL **OUTSIDE_IN** blocca tutto il traffico in ingresso.

3

Firewall DMZ

ASA-DMZ: permette HTTP/HTTPS verso Web Server (192.168.100.10). Blocca il traffico dal Web Server verso la rete interna.

4

Switch Core

VLAN 10–70 e 100 create. Trunk verso Router Centrale e ASA-DMZ. Porte di accesso assegnate per reparto.

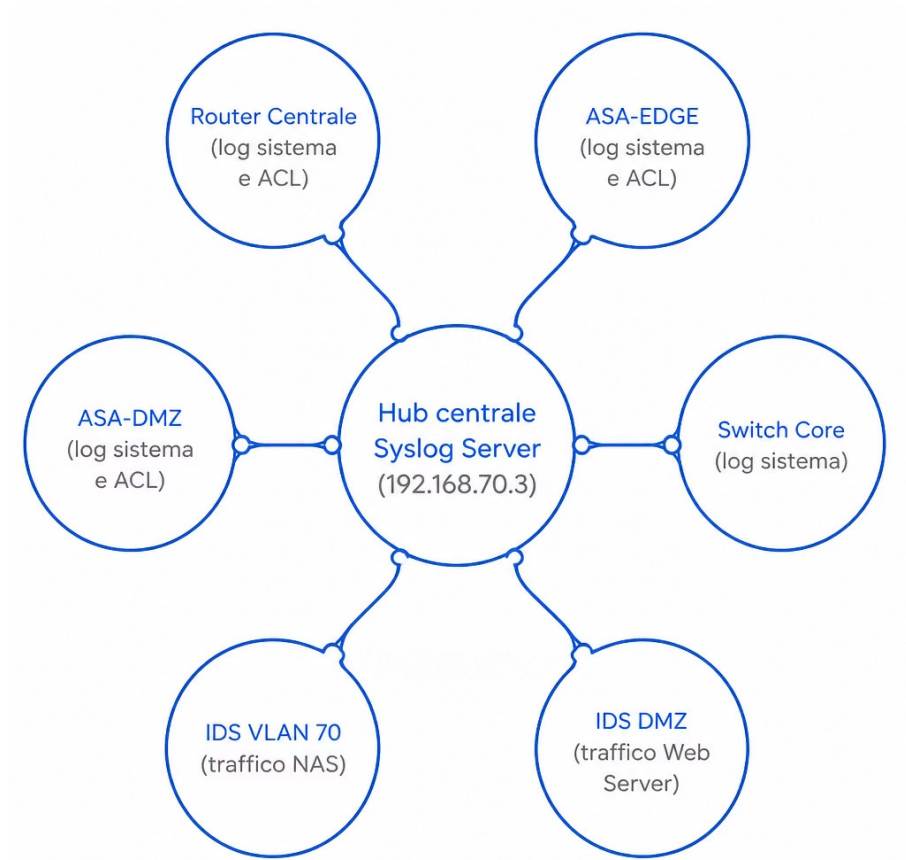
Monitoraggio: SPAN e Syslog

Sessioni SPAN

Il traffico del **NAS** (VLAN 70, Fa0/1) e del **Web Server** (VLAN 100, Fa0/1) viene copiato verso le interfacce IDS dedicate tramite SPAN.

Syslog Centralizzato

Tutti i dispositivi (router, firewall, switch, IDS) inviano log a **192.168.70.3** con logging trap debugging



Flussi di Traffico e Politiche di Sicurezza

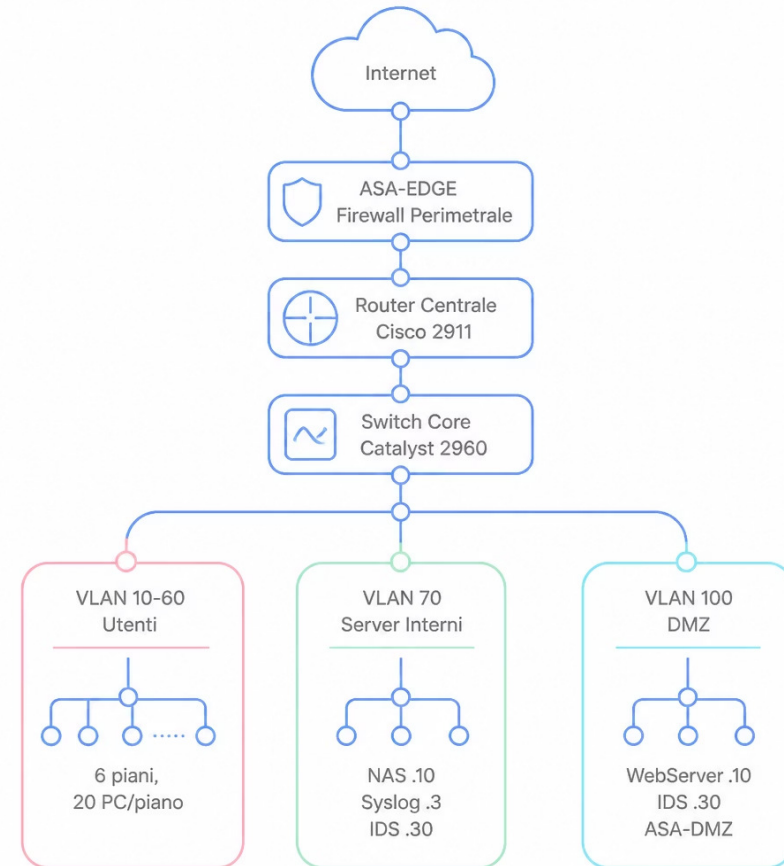
Traffico	Origine	Destinazione	Stato	Note
Internet → Rete interna	Cloud	LAN	Bloccato	Firewall ASA-EDGE
Internet → Web Server	Cloud	DMZ	✓ Consentito	HTTP/HTTPS via ASA
Utenti → Web Server	VLAN 10–60	DMZ	✓ Consentito	Via ASA-DMZ
Utenti → NAS	VLAN 10–60	VLAN 70	✓ Consentito	Routing inter-VLAN
Web Server → Rete interna	DMZ	LAN	Bloccato	Firewall ASA-DMZ
IDS → Syslog	192.168.70.30 / .100.30	192.168.70.3	✓ Consentito	UDP 514

Topologia Finale

La topologia è divisa in due sezioni: **Core Network** (Internet → ASA-EDGE → Router Centrale → Switch Core) e **Access/Distribution** (VLAN 10–60 utenti, VLAN 70 server, VLAN 100 DMZ con NAS, Syslog, WebServer e IDS).



Tutte le VLAN sono attive. Routing inter-VLAN configurato. Due IDS monitorano NAS e Web Server. SPAN attiva su switch VLAN 70 e DMZ.



Audit di Sicurezza: Scansione Porte

Script `port_scanner.py` eseguito da Kali Linux (192.168.10.11) su Metasploitable (192.168.50.101). Superficie d'attacco **estremamente estesa**.

FTP (21) 4 Alto

Trasferimento file non cifrato, credenziali intercettabili.

Telnet (23) 4 Critico

Dati e password in chiaro. Disinstallare immediatamente.

NetBIOS/SMB (139/445) 4 Alto

Storicamente affetta da exploit RCE critici.

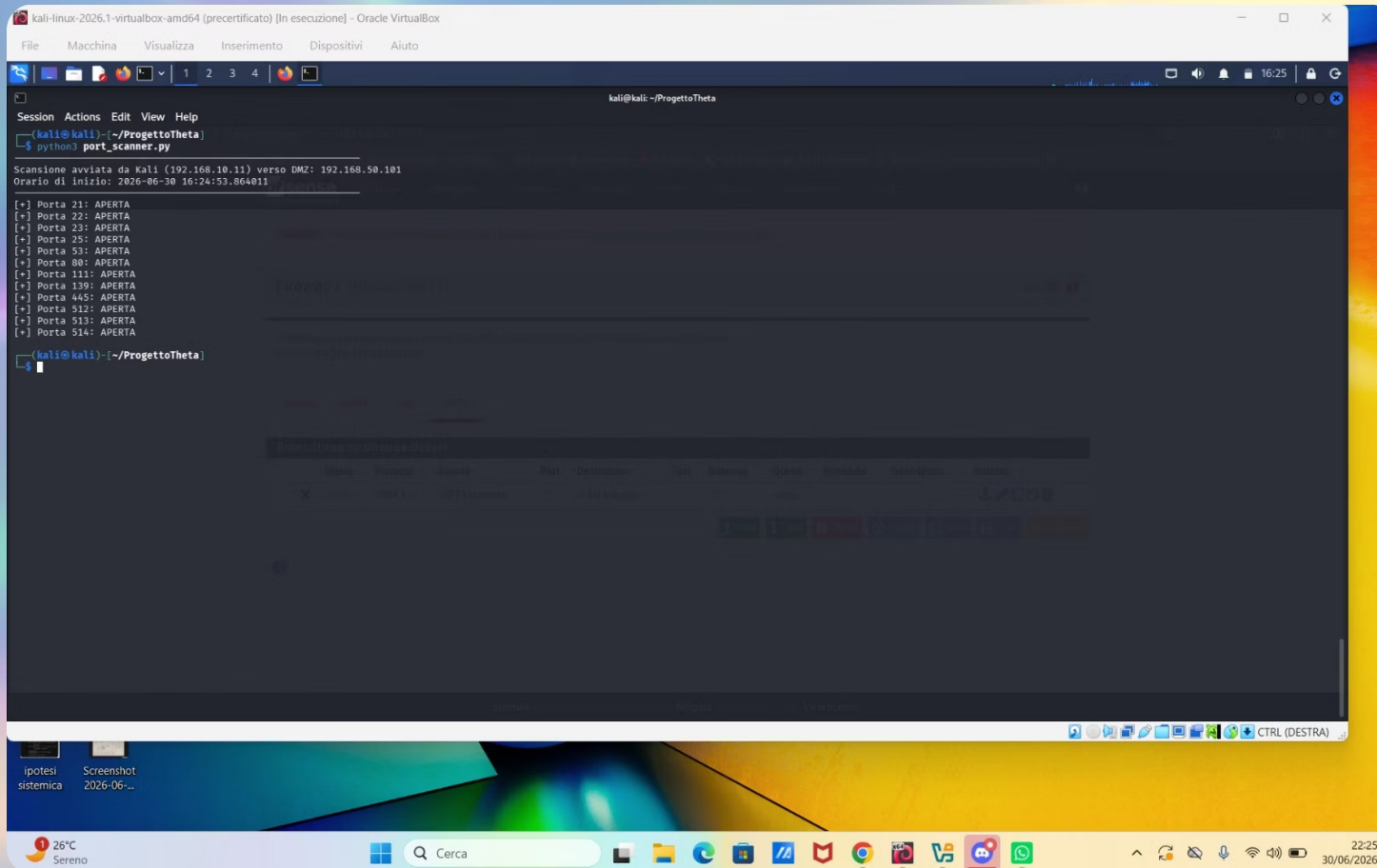
R-services (5123514) 4 Critico

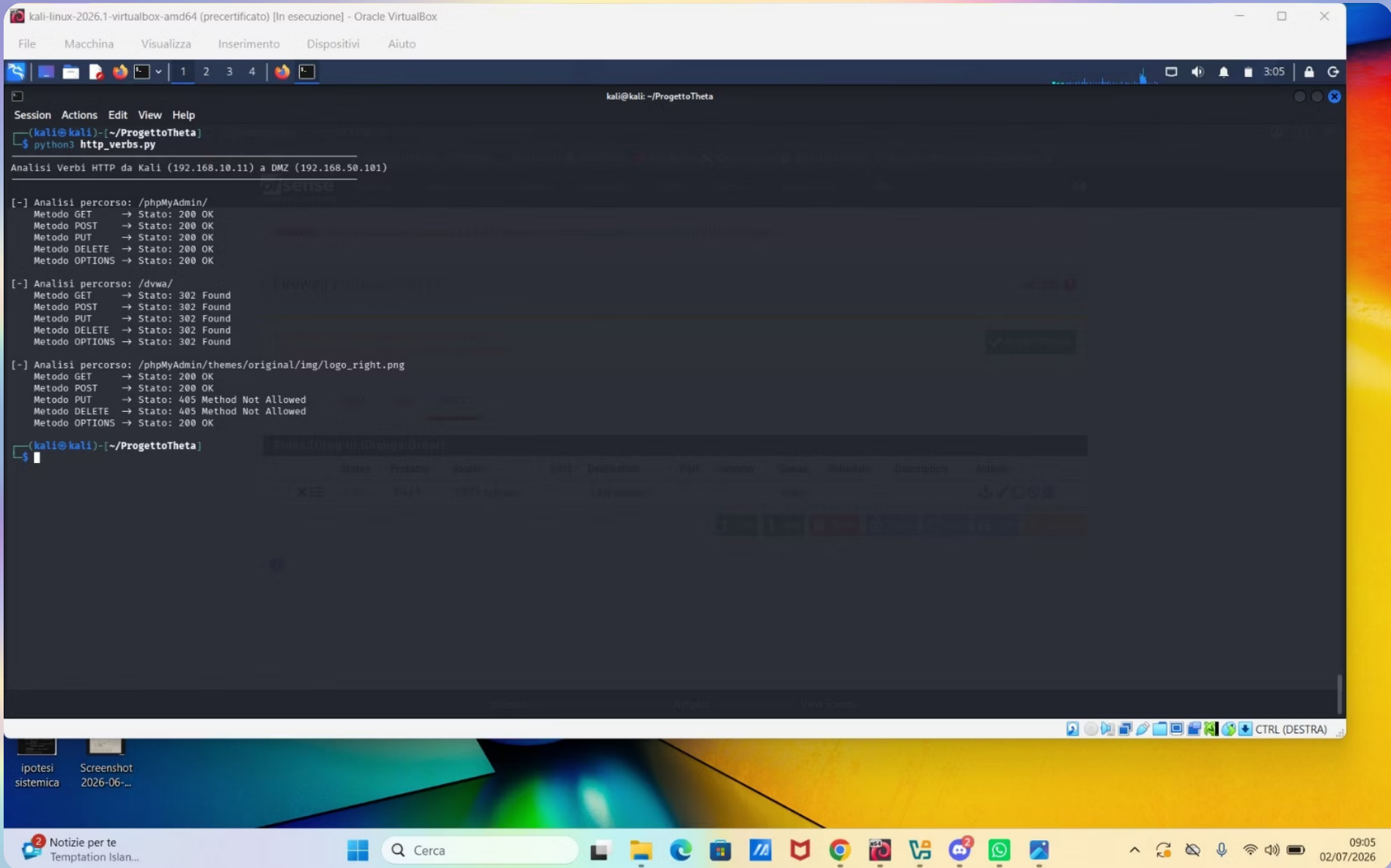
Login remoto obsoleto con autenticazione debole.

 **Raccomandazione:** Policy "Default Deny" su pfSense 4 bloccare porte 21, 23, 445, 5123514; consentire solo 80/443.

The screenshot shows a Kali Linux desktop environment with a blue geometric wallpaper. On the left, there are icons for 'Home', 'File System', 'Trash', and a folder named 'bw1'. A terminal window is open in the center, displaying the output of a Python script. The script performs a port scan on 192.168.2.10 and verifies HTTP verbs for two URLs. The desktop has a taskbar at the bottom with various application icons and a system tray on the right showing the time as 5:38.

```
kali@kali: ~  
Session Actions Edit View Help  
~(kali@kali)-[~]  
$ python3 /home/kali/Desktop/bw1/tests.py  
( 'SCANSIONE DELLE PORTE', 0 )  
== SCANSIONE DELLE PORTE ==  
Avvio scansione su 192.168.2.10 dalla porta 79 alla 85 ...  
Porta 79 chiusa  
Porta 80: APERTA  
Porta 81 chiusa  
Porta 82 chiusa  
Porta 83 chiusa  
Porta 84 chiusa  
Porta 85 chiusa  
  
== SCANSIONE METODI PHPMYADMIN ==  
** URL: http://192.168.2.10/phpMyAdmin/ **  
Verifica dei verbi HTTP sul percorso: http://192.168.2.10/phpMyAdmin/  
  
Metodo GET      → Codice Stato: 200 OK | Content-Type: text/html; charset=utf-8  
Metodo POST     → Codice Stato: 200 OK | Content-Type: text/html; charset=utf-8  
Metodo PUT      → Codice Stato: 200 OK | Content-Type: text/html; charset=utf-8  
Metodo DELETE   → Codice Stato: 200 OK | Content-Type: text/html; charset=utf-8  
Metodo OPTIONS  → Codice Stato: 200 OK | Content-Type: text/html; charset=utf-8  
  
** URL: http://192.168.2.10/phpMyAdmin/themes/original/img/logo_right.png **  
Verifica dei verbi HTTP sul percorso: http://192.168.2.10/phpMyAdmin/themes/original/img/logo_right.png  
  
Metodo GET      → Codice Stato: 200 OK | Content-Type: image/png  
Metodo POST     → Codice Stato: 200 OK | Content-Type: image/png  
Metodo PUT      → Codice Stato: 405 Method Not Allowed  
Metodo DELETE   → Codice Stato: 405 Method Not Allowed  
Metodo OPTIONS  → Codice Stato: 200 OK | Content-Type: image/png
```





Analisi HTTP e Conclusioni

Endpoint /phpMyAdmin/ — Critico

PUT e DELETE restituiscono **200 OK**: possibile upload di Web Shell o defacement.

Endpoint /dwwa/ — Mitigato

Tutti i metodi restituiscono **302 Found**: reindirizzamento al login.

Risorsa Statica — Sicura

PUT/DELETE restituiscono **405 Method Not Allowed**: configurazione corretta.

Raccomandazioni Finali

- Bloccare verbi HTTP pericolosi via `.htaccess` su Apache
- Disinstallare Telnet e R-services su Metasploitable
- Centralizzare gestione remota su SSH (porta 22)
- Applicare policy "Default Deny" su pfSense

❏ La rete THETA è segmentata e monitorata, ma le criticità su pfSense e phpMyAdmin richiedono intervento immediato.

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH

DATA BREACH